

A NOVEL APPROACH TO QUANTIFYING SECURITY USING SAMM

Application security has never been more business-critical, yet security often comes too late in the development process. This article explores how the *OWASP Software Assurance Maturity Model (SAMM)* helps organizations measure, improve, and align application security with business goals.

According to the **2024 Data Breach Investigations Report**, applications are the most common method used by a cyber attacker to gain unauthorized access to IT systems. Despite awareness, the number of breaches is rising, especially in sectors like healthcare. One reason is that security is intangible. Other (IT) investments usually have a quantifiable benefit. For security, this is much more difficult until the business suffers. Additionally, startups and agile teams often skip security because it's not in the top 10 priorities.

The traditional software development lifecycle (SDLC) is predominantly focused on building software. Security is only introduced at specific stages of the development

pipeline. Thus, this reactive methodology often comes in when it is too late and too expensive to properly implement changes.

SECURE SDLC

Secure SDLC (SSDLC) is an idea to incorporate security in the software development lifecycle. It integrates security proactively into all phases of the development. An example of SSDLC is the recent rise of DevSecOps where organizations would augment the existing collaboration between developers and operations staff (DevOps) with security tooling as well as the security team thereby creating DevSecOps.

Integrating security throughout the development pipeline is a proactive approach. This method is concerned with laying a solid foundation rather than patching cracks. It is not only more effective in reducing risk but also more cost-efficient. As it allows teams to identify and address issues earlier, changes are easier and less expensive to implement.

APPSEC CORNERSTONES

The application security (AppSec) cornerstones are people, processes, knowledge and tools. The *people*-aspect means that security roles and responsibilities should be clear and the people responsible should be capable of fulfilling their role. The process-aspect includes having clear control gates, deliverables and activities enforcing security measures in the business. The knowledge-aspect is about implementing standards & guidelines, compliance, transfer methods. The last aspect encapsulates the tools used to implement security. An example of this is development tools, like an IDE, which can be employed by a programmer to write more secure code. Other tools are assessment tools and management tools.

More importantly though, all of these cornerstones revolve around the notion and understanding of risk. The framework doesn't assume that every control, process, or activity has the same importance for every organization. Different application risk profiles may apply. For instance, a bank app must have all-round security measures in place. This means that the SAMM maturity goals will be deep and extensive. By contrast, an internal accountant's tool in a restricted environment with limited access may not require the same level of security investment as the bank app.

SECURITY IS EVERYONE'S CONCERN

When implementing security in a business it should be clear that it is everyone's concern. It is not just something for the security team, but developers, testers, operators and business leaders need to play a role. Many stakeholders still see security only as the responsibility of the security team. As security is often a matter of the weakest link, it should be shared in reality across roles: business analysts must capture security requirements, architects should apply secure design principles, developers need to write secure code, and testers and quality-assurance must validate that security features work as intended.

Of course, not all security measures are equally important in every context. For the business to remain efficient and competitive it is crucial to align the security efforts with what matters the most to the organization. When these specific goals have been established, feedback loops and metrics can be leveraged. By measuring KPIs a business can adjust and improve security over time.

SOFTWARE ASSURANCE MATURITY MODEL

However, as with implementing any new technology in the business, it is difficult to know where to start. For a business, a proper starting point might be the software assurance maturity model (SAMM), a flagship project of the Open Worldwide

Application Security Project (OWASP). Its purpose is to help organizations measure, improve, and mature their software security practices. The model addresses the key issues with security as it provides an approach to measure security and make risk driven decisions that align with the business needs.

Thus, it can be considered for a wide range of companies. The model considers the business functions governance, design, implementation, verification and operations. Each function has three security practices, and each practice has two business processes that can reach three maturity levels. Examples of maturity levels for the business processes Education and Guidance (Governance) and Secure Build (Implementation) are in table 1.

TABLE 1: EXAMPLES OF MATURITY LEVELS FOR EDUCATION AND SECURE BUILD

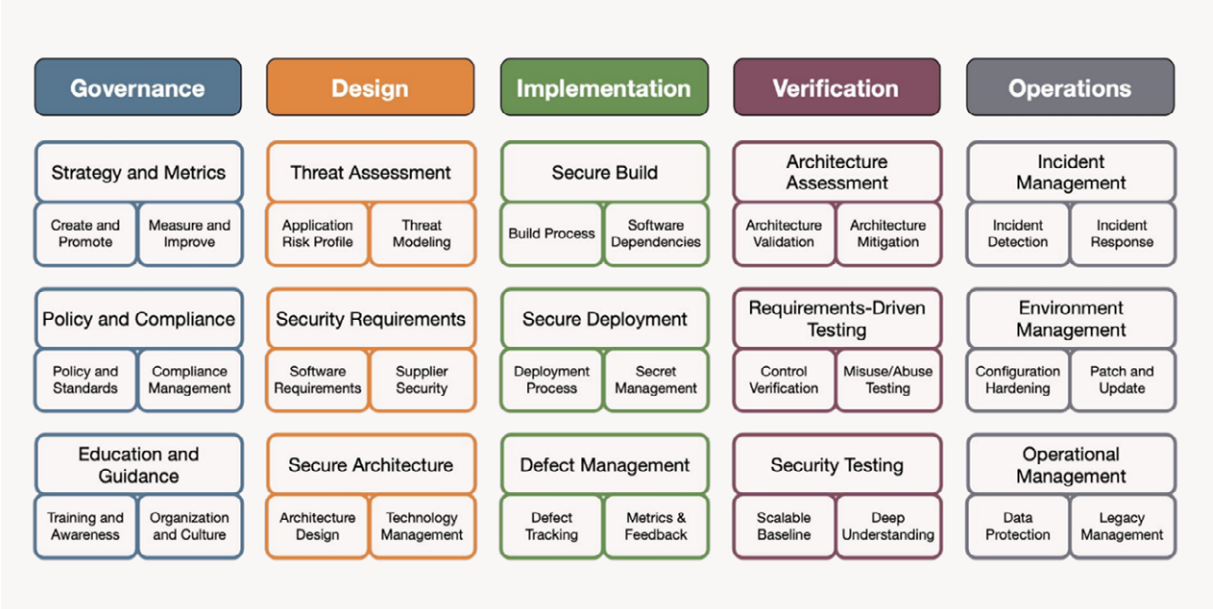
Maturity Levels (Example: Education) – table 1

- **Level 1:** Provide awareness training for devs.
- **Level 2:** Role-specific guidance and tools.
- **Level 3:** Fully standardized internal training with updates and metrics.

Maturity Levels (Example: Secure Build)

- **Level 1:** Define a consistent build process.
- **Level 2:** Automate builds, secure tools, add checks.
- **Level 3:** Enforce mandatory checks, reject non-compliant builds.

FIGURE 1: SAMM V2 MODEL OVERVIEW



Considering their risk profile, each organization decides how deep and in which way they apply the model. For instance, both a bank and a startup may consider verification but the bank might extensively simulate attacks while the startup might only run a few automated scans. The framework is the same, but the maturity targets differ per company.

Based on a questionnaire, companies are assigned to a maturity level for each business function described in SAMM. After completing the questionnaire, a total score for how secure a company is on each business function is obtained. The five business processes governance, operations, verification, implementation and design are ranked and compared to where the company wants to be in the future. These scorecards show how secure your organization is for each business function.

The scores make it possible to do gap analysis. Hence, target postures can then be used to gain an idea of how far teams have progressed in implementing security. In addition, the current and future state of a company can be compared and concrete roadmap building can be done. It also gives a clear overview of progress over time, showing an evolution of the security of your company.

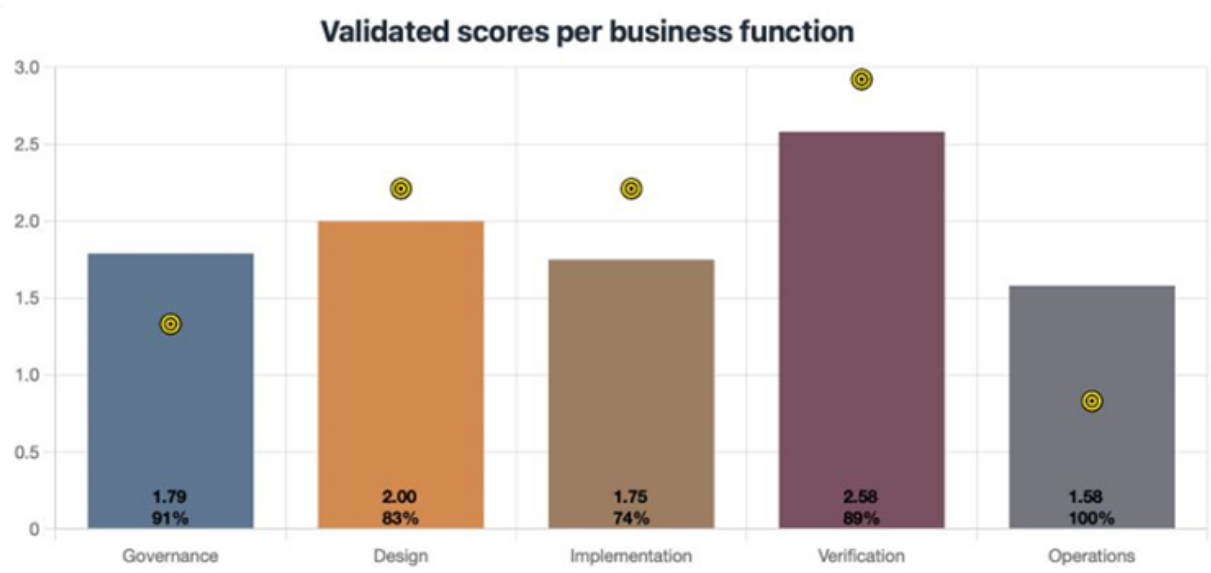
To properly use SAMM, first a scope should be set. Maybe you are concerned with security in the whole organization or just one department. Usually, teams following the same development process can be grouped together. When assessing security, a smaller scope will be more precise than a larger scope. The next step of the process is to gather stakeholders, including all sorts of roles like developers, testers, operations team, Security Champions and GRC staff to create an initial assessment of the selected scope. After this assessment, the gaps between current position and future objective are considered to build an improvement plan. Finally, the teams will have to work on these improvements and roll them out across the planned scope.

Additionally, it's important to note that many SAMM activities require a continuous effort, especially at higher maturity levels. Due to the evolution of technology, security will always be a race between attackers and defenders. This means that achieving a certain score is one thing, but constant investments are needed to maintain that score. SAMM models this effect using score expiration, where the score automatically drops unless activities are maintained.

1. *According to the OWASP SAMM framework, Security Champions serve as the primary security contact within their team. They meet with the security team for guidance and help bridge communication gaps between development and security. Because they understand their teammates' codebases and working culture, Security Champions can align security such that it resonate with the team. This makes them a key enabler of application security maturity.*

2. *Governance, Risk, and Compliance (GRC) professionals are dedicated to a company-wide approach to managing decision-making, risk, and regulatory compliance.*

FIGURE 2: SAMM ENABLES GAP ANALYSIS BETWEEN FUTURE OBJECTIVES AND CURRENT POSITION



From https://sammy.codific.com

CONCLUSION

Security is a continuous journey, not a one-time fix. The central attacking point of adversaries has shifted to applications. Hence, pre-emptive security approaches are receiving more attention to integrate security practices earlier in the software development lifecycle, rather than treating it as a separate phase at the end. In addition, no company is 100% secure. However, as running a business intrinsically comes with trade-offs it is important to assess which security aspects are the most crucial.

For companies it is difficult to adapt to the vastly changing security environment. Adding to the challenge are the specific security needs of a company. This is where SAMM comes in. Just like a Swiss Army knife, it will provide a tailored risk-driven approach to implement security in your organization based on what it means for the organization to be secure. It considers security over many business functions and not just development. OWASP SAMM is free, open, and designed to help all types of teams. The model helps bridge the gap between business goals and technical practices. As each SAMM activity has clear maturity levels to grow into, businesses can define clear objectives to reach. Lastly, the model also comes in handy for audits or Mergers and Acquisitions assessments. For instance, when one company merges with or acquires another, the security maturity and risk can be verified and evaluated. Hence, OWASP SAMM can evaluate AppSec maturity before a merger closes, reducing integration risk.



This article is based on a presentation by Aram Hovsepyan (CEO Codific and OWASP SAMM core team member). Article written by Jasper Visterin (KU Leuven).